

PCI DSS COMPLIANCE ASSESSMENT

Elite HealthCare — Payment Card Security Review

Prepared by: JVK Enterprise Holding Solutions LLC | April 2026

1. Executive Summary

This PCI DSS Compliance Assessment was conducted for Elite Healthcare to evaluate the organization's adherence to the Payment Card Industry Data Security Standard (PCI DSS) version 4.0. Because Elite Healthcare accepts credit and debit card payments for patient billing, PCI DSS compliance is a mandatory regulatory requirement. This document identifies compliance gaps across all 12 PCI DSS requirements, assesses current risk levels, and provides actionable remediation recommendations to achieve full compliance.

2. Organization Overview

- Organization: Elite Healthcare
- Industry: Healthcare outpatient medical clinic
- Employees: 20 staff members across one location
- Payments accepted: Credit cards, debit cards, HSA/FSA cards
- PCI DSS Merchant Level: Level 4
- Regulatory scope: PCI DSS v4.0, HIPAA Privacy and Security Rules
- Assessment type: Internal Self-Assessment Questionnaire (SAQ) review

3. What Is PCI DSS?

The Payment Card Industry Data Security Standard (PCI DSS) is a global security standard developed by the PCI Security Standards Council, founded by American Express, Discover, JCB, MasterCard, and Visa. The standard applies to any organization that stores, processes, or transmits cardholder data.

PCI DSS includes 12 core requirements organized under six major security goals:

- 1. Build and maintain a secure network and systems (Req. 1–2)
- 2. Protect account data (Req. 3–4)
- 3. Maintain a vulnerability management program (Req. 5–6)
- 4. Implement strong access control measures (Req. 7–9)
- 5. Regularly monitor and test networks (Req. 10–11)
- 6. Maintain an information security policy (Req. 12)

Non-compliance may result in fines, increased transaction fees, loss of payment-processing privileges, and reputational damage.

4. Compliance Summary

Status	Count	Percentage	Priority
Compliant	2	17%	Maintain
Partial	5	42%	High
Non-Compliant	5	42%	Critical

5. Detail Requirements Assessment

Req	Title	Description	Status	Current Gap	Recommendation
Req 1	Install and maintain network security controls	Firewalls and network segmentation must protect cardholder data environments.	Partial	Farmer network segmentation is documented between billing and clinical systems	Document network topology, implement firewall rules separating CDE from other systems

Req 2	Applies secure configurations	Default passwords and unnecessary service and must be removed from all systems	Non-Compliant	Several workstations are still using vendor default settings	Conduct a systems hardening review, change all default Credentials, and disable on you services
Req 3	Protect store account data	Car holder data must be encrypted or masked when stored	Partial	Payment data is stored in billing systems, but encryption is not verified	Verify encryption at rest on the billing platform, and implement a data minimization policy
Req 4	Protect cardholder data with strong cryptography during transmission	Data must be encrypted in transit using TLS 1.2 or higher	Compliant	TLS 1.2 confirmed on payment processing portal	Maintain current TLS version review annually for deprecated protocols
Req 5	Protect all systems against malware	Anti-malware must be deployed on all systems	Partial	Antivirus is installed, but not centrally managed or updated consistently	Deploy centrally managed endpoint protection with automatic updates
Req 6	Develop and maintain secure systems and software	Systems must be patched, and vulnerabilities remediated properly	Non-Compliant	No formal patch management process in place	Establish a monthly patch cycle, prioritize critical patches within 30 days

Req	Title	Description	Status	Current Gap	Recommendation
Req 7	Restrict access to system components	Access to cardholder data must be limited by business need	Non-Compliant	All billing staff have full access regardless of role	Implemented role-based access controls that apply least privilege principles
Req 8	Identify the user and authenticate access	Unique IDs and strong Authentication required for all users	Partial	Unique IDs are in place, but MFA is not enforced on billing systems	Enable MFA on all systems accessing cardholder data

Req 9	Restrict physical access to cardholder data	Physical access to systems and data must be controlled	Compliant	Serving room, lock, and visitor log maintenance	Continue current controls review, physical access, and quarterly review
Req 10	Log and monitor all access	All access to the network and cardholder data must be logged	Non-Compliant	Blogging is enabled, but logs are not reviewed or retained for 12 months	Implemented log review process, configured 12-month log retention
Req 11	Test the security of systems and networks	Regular vulnerability scans and penetration test required	Non-Compliant	No vulnerability scanning or penetration testing conducted	Schedule quarterly internal scans and annual penetration tests
Req 12	Support information security with organizational policies	Former information security policies must exist and be maintained	Partial	Basic IT policy exists, but no PCI DSS specific	Develop a comprehensive PCI DSS security policy and conduct annual staff training.

6. Critical Findings

The following five areas require immediate attention:

Finding 1 — No Patch Management Process (Req 6)

Elite Healthcare does not have a formal patch management process. Unpatched systems are one of the most common attack vectors in healthcare data breaches. Without regular patching, no vulnerabilities remain open and exploitable. Recommendation: Establish a monthly patch cycle with critical patches applied within 30 days of release.

Findings 2 — No Role-Based Access Control (Req 7)

All billing staff currently have full access to cardholder data regardless of their specific job function. This violates the principle of least privilege, which is foundational to PCI DSS. Recommendation: Define access levels by job role and implement controls ensuring staff can only access data necessary for their specific duties.

Findings 3 — No Log Review Process (Req 10)

Although login is enabled on some systems, there is no formal log review process, and logs are not retained for the required 12-month period. Without log monitoring, unauthorized access to cardholder data could be undetected for extended periods. Recommendation: Implement automatic log review and configure 12-month retention with at least 3 months immediately available.

Findings 4 — No Vulnerability Scanning or Penetration Testing (Req 11)

Elite Healthcare has never conducted a form of vulnerability scam or penetration test. PCI DSS requires quarterly vulnerability scans by an Approved Scanning Vendor (ASV) and an annual penetration test. Recommendation: Engage an ASV for quarterly external scans and schedule an annual penetration test.

Findings 5 — Default System Configuration (Req 2)

Multiple workstations retain vendor default passwords and configurations. Default credentials are publicly known and represented as an easy entry point for attackers. Recommendation: Conduct an immediate audit for all systems, change all default credentials, and disable unnecessary service imports.

1. Remediation Roadmap

Priority	Action Item	Owner	Timeline
Critical	Change all default passwords and harden system configurations	IT Security Officer	Immediate

Critical	Infinite Roll Base Access controls for billing systems	IT Security Officer	30 days
Critical	Enable MFA on all systems accessing cardholder data	IT Security Officer	30 days
High	Establish a formal patch management process	IT Security Officer	60 days
High	Implement a log review process and 12-month retention	IT Security Officer	60 days
High	Deploy centrally managed endpoint protection	IT Security Officer	60 days
Medium	Schedule quarterly vulnerability scans with ASV	Compliance Team	90 days
Medium	Develop comprehensive PCI DSS security policies	Privacy Officer	90 days
Medium	Schedule annual penetration tests	Compliance Team	6 months

2. Conclusion

Healthcare currently has significant PCI DSS compliance gaps that expose the organization to financial penalties, reputational harm, and an increased risk of a payment card data breach. Of the 12 PCI DSS requirements assessed, only 2 are fully compliant. Five requirements are non-compliant and require immediate remediation. By following the prioritized roadmap outlined in this document, Elite Healthcare can substantially reduce its risk exposure and achieve PCI DSS compliance within 6 months. I'm going to comply with annual assessments, quarterly vulnerability scans, and continuous staff training.